

SIMULAZIONE SPEAR-PHISHING & ADVERSARIAL AI

Obiettivo: Svolgere una ricerca OSINT su Jeff Bezos e sul contesto Blue Origin, progettare uno scenario di spear-phishing personalizzato e analizzarne credibilità, limiti e contromisure.

Target strategico: Jeff Bezos.

Organizzazione analizzata: Blue Origin.

Strumenti utilizzati: Ricerca Google con filtro notizie, LinkedIn, Maltego, theHarvester su Kali Linux e un Large Language Model per la generazione controllata del contenuto.

1. Sintesi

La ricerca ha preso avvio dalla selezione di Jeff Bezos come target strategico. L'analisi delle attività pubbliche riconducibili al target ha portato a concentrare l'attenzione su Blue Origin e, in particolare, sulla recente ricerca di capitale esterno. Secondo Reuters, Blue Origin sta cercando di raccogliere circa 10 miliardi di dollari con una valutazione di 130 miliardi, e con Coatue Management indicata come potenziale lead investor e un impegno atteso di circa 4 miliardi di dollari.

Forbes Italia ha presentato la stessa operazione come una raccolta già realizzata. Questa differenza terminologica è stata mantenuta nella relazione come limite informativo delle fonti giornalistiche.

L'OSINT è proseguito con l'analisi di LinkedIn e con la costruzione di un grafico Maltego per rappresentare la leadership e l'area Finance di Blue Origin. È stato inoltre eseguito theHarvester sul dominio blueorigin.com, ottenendo dati su ASN, URL, indirizzi IP, un indirizzo e-mail pubblico e numerosi record host. I risultati hanno mostrato come informazioni frammentarie e lecite, quando correlate, possano supportare la costruzione di un pretesto molto specifico.

Lo scenario elaborato prevede che un attaccante impersoni una figura appartenente alla funzione Finance di Coatue Management e inviti un collaboratore Finance Operations di Blue Origin a una breve riunione riservata sulla due diligence. Il collegamento dell'e-mail rimanderebbe, in via teorica, a un falso portale di autenticazione aziendale/SSO. Le credenziali ottenute rappresenterebbero un possibile accesso iniziale, dal quale l'avversario potrebbe tentare un successivo movimento laterale verso account, risorse e relazioni più vicine alla leadership e all'Executive Office di Jeff Bezos.

Un eventuale impiego di deepfake audiovisivi è stato ipotizzato come possibile amplificatore della fiducia in seguito a un possibile successo dello spear phishing.

2. Consegna e metodologia

La consegna richiedeva: selezione del target e raccolta OSINT; progettazione di uno scenario di attacco personalizzato; uso di un LLM per generare il contenuto; debriefing e analisi critica della credibilità, delle red flag e delle difese possibili.

La metodologia adottata è stata la seguente:

- ricerca Google ordinaria, con filtro Notizie, per individuare progetti e investimenti recenti;
- ricerca su LinkedIn per identificare figure professionali, ruoli e relazioni pubblicamente dichiarate;
- uso di Maltego per correlare persone, funzioni aziendali e indirizzi e-mail probabili;
- uso di theHarvester per raccogliere informazioni pubbliche sul dominio blueorigin.com;

- progettazione di un pretesto coerente con il contesto finanziario emerso;
- generazione controllata dell'e-mail tramite LLM, dichiarando espressamente lo scopo didattico e difensivo;
- analisi critica dell'efficacia teorica e delle contromisure.

Non è stato eseguito Google Dorking avanzato. Alcune ricerche come Blue Origin filetype:pdf hanno portato alla scoperta di vecchi organigrammi dell'azienda. Tuttavia, nessun dork ha prodotto risultati soddisfacenti. Inoltre non sono stati utilizzati moduli attivi di enumerazione web, non sono state verificate le caselle e-mail tramite SMTP, procedure di recupero password o tentativi di login.

3. Raccolta OSINT

3.1 Ricerca web e contesto finanziario

La ricerca tramite Google e filtro Notizie ha evidenziato il primo importante ricorso di Blue Origin a capitale esterno. Reuters ha descritto l'operazione come una raccolta in corso. Coatue Management compare come soggetto centrale del round e ciò rende credibile, dal punto di vista narrativo, una comunicazione relativa a incontri preliminari, due diligence o coordinamento tra dipartimenti Finance.

I dati OSINT non dimostrano l'esistenza di una specifica riunione né l'assegnazione di un determinato referente. Forniscono però un contesto temporale e operativo sufficiente a costruire un pretesto coerente: la vittima potrebbe ritenere plausibile una richiesta proveniente da un investitore istituzionale già citato dalla stampa.

3.2 Ricerca LinkedIn e ricostruzione organizzativa

La ricerca su LinkedIn ha permesso di individuare figure pubblicamente associate alla leadership e all'area Finance di Blue Origin. Tra i ruoli ricostruiti figurano Dave Limp come CEO, Allen Parker come CFO, Bhavesh Patel nell'area Operations/Strategy, Andrew Reece come Vice President Finance, William (BJ) Patterson come Senior Director - Finance Operations e Dave Piechowski nell'area Treasury.

Le relazioni gerarchiche complete non risultano confermate da un organigramma ufficiale: il grafo rappresenta quindi una mappa analitica basata su titoli professionali pubblici e ruoli all'interno dell'azienda.

Un post LinkedIn pubblico e i profili correlati hanno fornito elementi sufficienti per associare nomi, funzioni e appartenenza al team Finance. Questo dimostra il valore dell'OSINT sociale: un singolo contenuto, combinato con commenti, titoli e profili pubblici, può ridurre sensibilmente il lavoro necessario per selezionare una funzione bersaglio e adattare linguaggio e pretesto.

Mappatura OSINT tramite Maltego

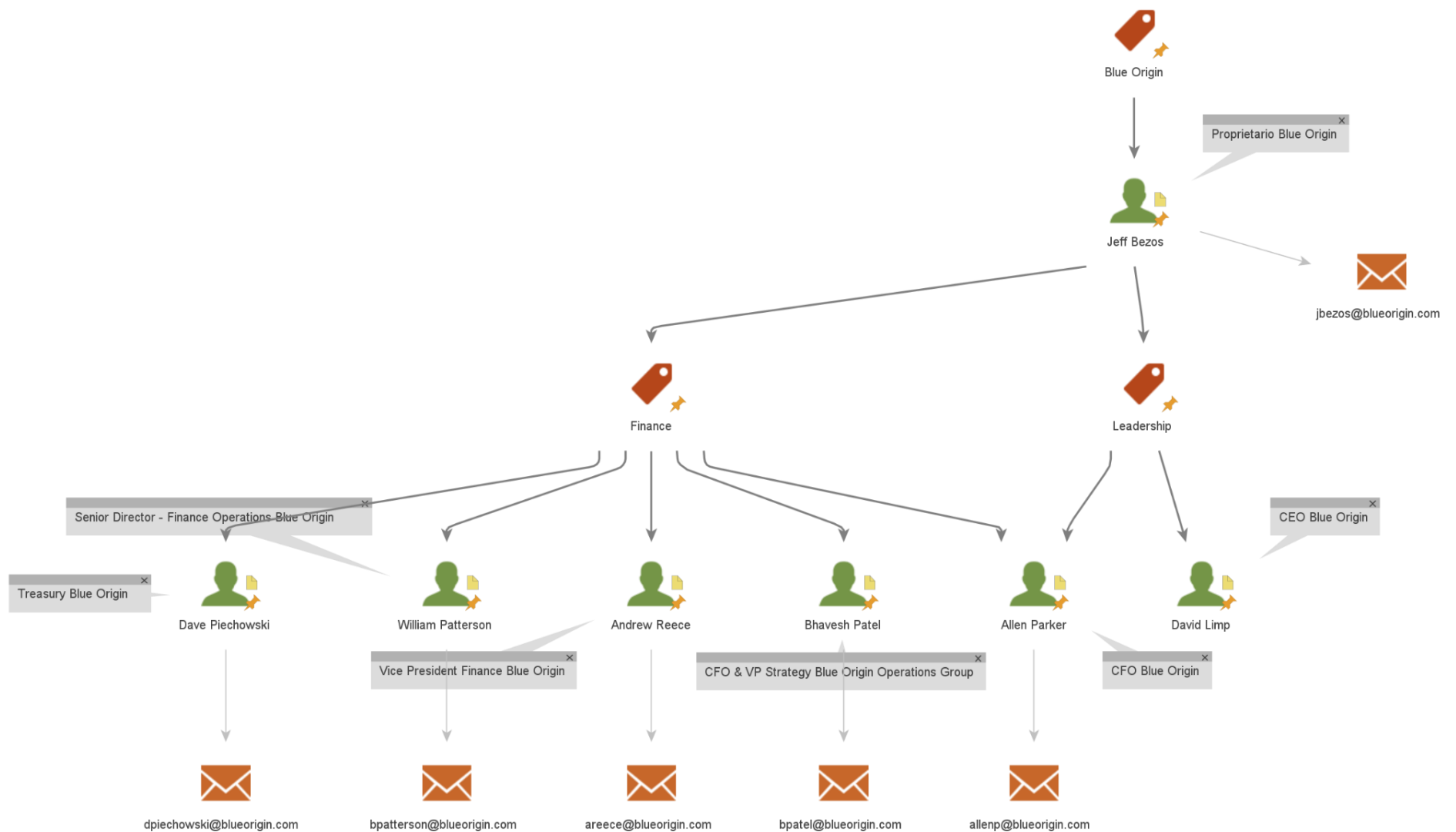


Figura 1 - Grafico Maltego utilizzato per correlare Jeff Bezos, Blue Origin, le aree Leadership e Finance, i ruoli pubblici e gli indirizzi e-mail probabili. Le frecce verso le aree funzionali rappresentano un collegamento contestuale e non necessariamente un rapporto gerarchico confermato.

3.3 Analisi con Maltego

Maltego è stato utilizzato come strumento di correlazione e rappresentazione. Partendo dal dominio aziendale e dai nomi individuati, sono stati aggiunti i ruoli pubblici e gli indirizzi e-mail restituiti dai Transform. In assenza di una fonte diretta o di un URL che dimostri la pubblicazione dell'indirizzo, il risultato è stato classificato come "indirizzo probabile dedotto dal pattern aziendale".

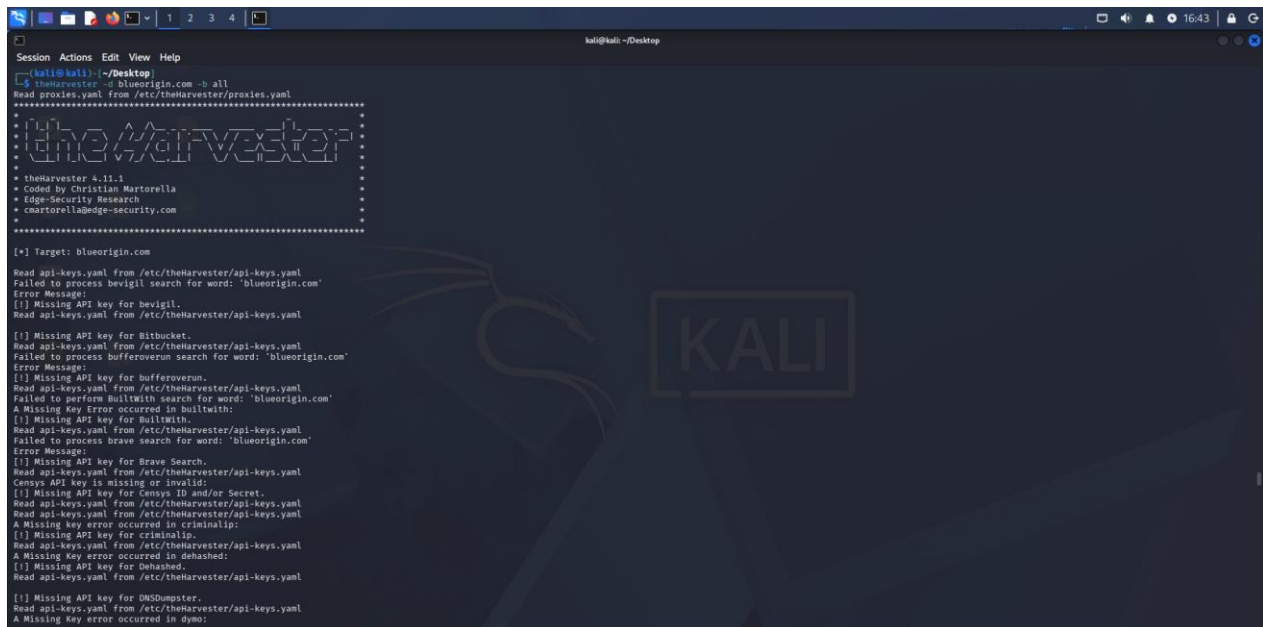
Questa distinzione evita un errore frequente nell'OSINT: confondere un valore generato o stimato da un provider con un dato confermato. Gli indirizzi non sono stati contattati né verificati attivamente. Nella parte narrativa dell'esercizio vengono quindi usati come esempio di esposizione potenziale, non come prova della reale assegnazione della casella.

3.4 Ricerca con theHarvester

È stato eseguito theHarvester su Kali Linux con il seguente comando:

```
theHarvester -d blueorigin.com -b all
```

L'opzione -b all ha tentato di interrogare tutte le sorgenti supportate, ma l'output mostra che numerosi moduli non hanno potuto operare a causa dell'assenza di API key, credenziali non valide o servizi non disponibili. Il risultato deve quindi essere considerato parziale e dipendente dalle fonti che hanno risposto correttamente.



```
kali@kali: ~/Desktop
Session Actions Edit View Help
kali@kali:~/Desktop$ theHarvester -d blueorigin.com -b all
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
  theHarvester
*****
• theHarvester 4.11.1
• Coded by Christian Martorella
• Edge-Security Research
• cmartorella@edge-security.com
*****

[*] Target: blueorigin.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bevigil search for word: 'blueorigin.com'
Error Message:
[!] Missing API key for bevigil.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for Bitbucket.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bufferoverrun search for word: 'blueorigin.com'
Error Message:
[!] Missing API key for bufferoverrun.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to perform builtwith search for word: 'blueorigin.com'
A Missing Key Error occurred in builtwith:
[!] Missing API key for builtwith.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process brave search for word: 'blueorigin.com'
Error Message:
[!] Missing API key for Brave Search.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Censys API key is missing or invalid.
[!] Missing API key for Censys ID and/or Secret.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing key error occurred in criminalip:
[!] Missing API key for criminalip.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing Key error occurred in dehashed:
[!] Missing API key for Dehashed.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for DNODumpster.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing Key error occurred in dno:
```

Figura 2 - Avvio di theHarvester e messaggi relativi alle API key mancanti. Il comando non ha quindi utilizzato con successo tutte le fonti previste dall'opzione "all".

Sintesi dell'output:

Categoria	Valore rilevato	Interpretazione
ASN	5	Riferimenti a reti autonome osservate nelle fonti interrogate.
URL interessanti	22	URL classificati dal tool come rilevanti; la classificazione non equivale a una vulnerabilità.
Indirizzi IP	34	Indirizzi associati ai record raccolti, inclusi provider cloud e servizi esterni.
E-mail	1	privacy@blueorigin.com, indirizzo pubblico di funzione.
Persone	0	Nessuna persona individuata direttamente dal tool.
Record host	425	Record grezzi comprensivi di duplicati, mappature IP e CNAME.

```

kali@kali: ~/Desktop
Session Actions Edit View Help
[*] ASNs Found: 5
AS13335
AS16589
AS47382
AS47674
AS8987

[*] Interesting Urls found: 22
http://www.blueorigin.com/
http://sproxy-stg.blueorigin.com/
http://www.blueorigin.com/
https://auth.blueorigin.com/
https://blueorigin.com/
https://customshop.blueorigin.com/
https://infoexchange.blueorigin.com/UserWeb/Login/Login.aspx?ReturnURL=%2FUserWeb%2FCommon%2FSetupServices.ashx%3FglD%3D1674e3aa-bc6e-48bc-802b-09ce6c7c7b36826cnd%3DdownloadExportedPDF%26itemID%3D5398bb42-9eba-466d-01f4-30b4c9d52cbd%26
f330e99b7308x3JTLV4eK43BAV7pYKTL4DC3CR3V475209W0J2YL3AMQD5752G2PVYBC66CCPADX246DU5AMK24SEVVEFREDY88A773PL73TF3A4L298FENJL7C26subItemID%3D121485d6-2340-495e-b5dd-156c7b19045b26f1lePath%3DC%2531A255C%253C18F0F0
d-8233-4278-ac8f-d35e94e3366c.pdf%26fileName%3DWP6-463156-0084X2520WJW-DanielX2520DeKoeyerX2520W6LdX2520Certs(WP6-463156-0084X2520WJW-DanielX2520DeKoeyerX2520W6LdX2520Certs)BpId%3D1674e3aa-bc6e-48bc-802b-09ce6c7c7b36826cnd%3DdownloadExportedP
DFItemID%3D5398bb42-9eba-466d-01f4-30b4c9d52cbd%3FwY99HTZ20W6JTLV4eK43BAV7pYKTL4DC3CR3V475209W0J2YL3AMQD5752G2PVYBC66CCPADX246DU5AMK24SEVVEFREDY88A773PL73TF3A4L298FENJL7C26subItemID%3D121485d6-2340-495e-b5dd-156c7b19045b26f1lePath%3C
3A5C%253C18F0F0d-8233-4278-ac8f-d35e94e3366c.pdf%3FfileName%3DWP6-463156-0084X2520WJW-DanielX2520DeKoeyerX2520W6LdX2520Certs(WP6-463156-0084X2520WJW-DanielX2520DeKoeyerX2520W6LdX2520Certs)BpId%3D1674e3aa-bc6e-48bc-802b-09ce6c7c7b36826cnd%3DdownloadExportedP
https://sftp.blueorigin.com/
https://sftp.blueorigin.com/Web/Account/Login.htm
https://sftp.blueorigin.com/manageaccount
https://shop.blueorigin.com/
https://www.blueorigin.com/
https://www.blueorigin.com/careers/search?employmentType=Intern
https://www.blueorigin.com/destinations
https://www.blueorigin.com/es-xx
https://www.blueorigin.com/fr-fr
https://www.blueorigin.com/news/new-glenn-3-to-launch-ast-spacemobile-bluebird-satellite?AccountID=9112480hash=BE85C1053A7A722D31D4EBC1856BC17BF91FB8E9C3B231E0703B0E85800BA081A89E8F9980A745E0D611455809D083089294C336889C38708FBF2385F4
8F98utm_source=newsletter&utm_medium=email&utm_campaign=newsletterclick
https://www.blueorigin.com/pt-br
https://www.blueorigin.com/pt-br/news/new-shepard-nx-38-mission
https://www.blueorigin.com/supplier-terms-and-conditions
https://www.blueorigin.com/terawave

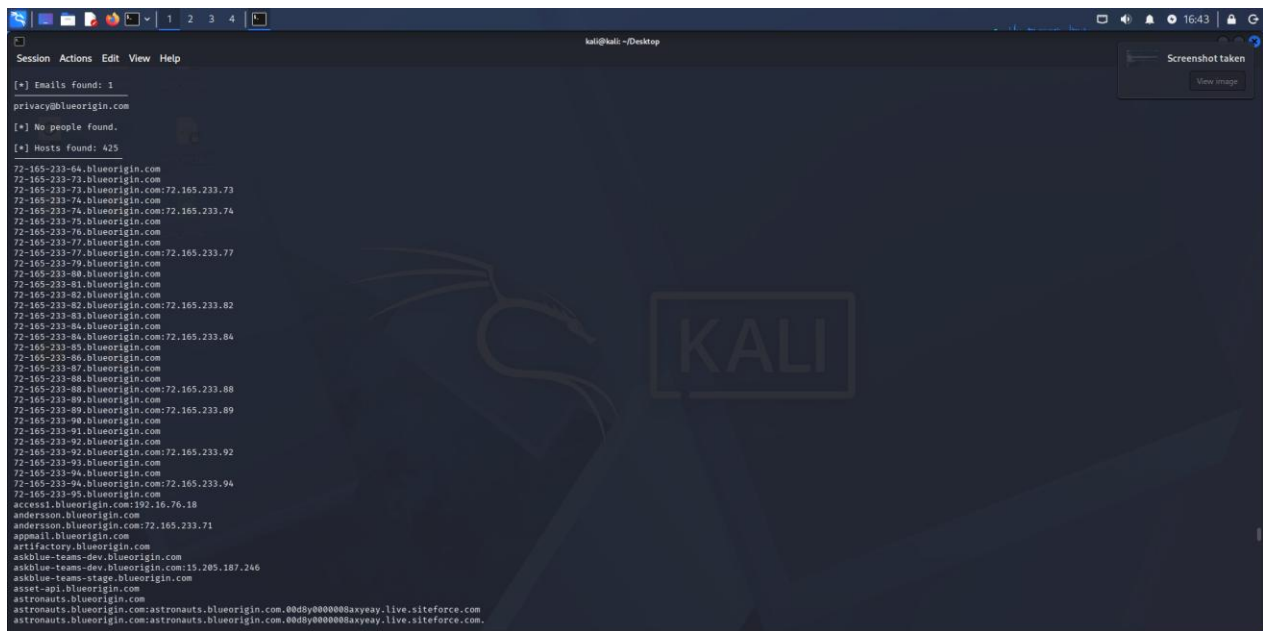
[*] No LinkedIn users found.

[*] LinkedIn Links found: 0

[*] IPs found: 34
104.20.30.25
104.20.31.25
15.197.253.45
15.205.161.110
15.205.199.186
195.61.171.171

```

Figura 3 - Estratto dei risultati theHarvester con ASN, URL classificati come interessanti e indirizzi IP.



```
Session Actions Edit View Help
[+] Emails found: 1
privacy@blueorigin.com
[+] No people found.
[+] Hosts found: 425
72-165-233-64.blueorigin.com
72-165-233-73.blueorigin.com
72-165-233-72.blueorigin.com:72.165.233.73
72-165-233-74.blueorigin.com
72-165-233-74.blueorigin.com:72.165.233.74
72-165-233-76.blueorigin.com
72-165-233-77.blueorigin.com
72-165-233-77.blueorigin.com:72.165.233.77
72-165-233-79.blueorigin.com
72-165-233-80.blueorigin.com
72-165-233-81.blueorigin.com
72-165-233-82.blueorigin.com
72-165-233-82.blueorigin.com:72.165.233.82
72-165-233-83.blueorigin.com
72-165-233-84.blueorigin.com:72.165.233.84
72-165-233-85.blueorigin.com
72-165-233-86.blueorigin.com
72-165-233-87.blueorigin.com
72-165-233-88.blueorigin.com:72.165.233.88
72-165-233-89.blueorigin.com
72-165-233-89.blueorigin.com:72.165.233.89
72-165-233-90.blueorigin.com
72-165-233-91.blueorigin.com
72-165-233-92.blueorigin.com
72-165-233-92.blueorigin.com:72.165.233.92
72-165-233-93.blueorigin.com
72-165-233-94.blueorigin.com
72-165-233-94.blueorigin.com:72.165.233.94
72-165-233-95.blueorigin.com
access1.blueorigin.com:192.16.76.18
anderson.blueorigin.com
anderson.blueorigin.com:72.165.233.71
appmail.blueorigin.com
artifactory.blueorigin.com
askblue-teams-dev.blueorigin.com
askblue-teams-dev.blueorigin.com:15.205.187.246
askblue-teams-stage.blueorigin.com
asset-api.blueorigin.com
astronauts.blueorigin.com
astronauts.blueorigin.com:astronauts.blueorigin.com.0008y0000000axeyay.live.siteforce.com
astronauts.blueorigin.com:astronauts.blueorigin.com.0008y0000000axeyay.live.siteforce.com.
```

Figura 4 - Estratto finale dell'output con l'indirizzo e-mail pubblico e l'elenco dei record host.

Il naming degli host suggerisce l'esistenza di categorie funzionali come autenticazione, posta, VPN, ambienti dev/stage, GitLab, portali fornitori, SFTP e sistemi di collaborazione. Questa è tuttavia una classificazione lessicale basata sui nomi DNS: non dimostra che i servizi siano attivi, raggiungibili o configurati come suggerito dal nome. Non è stata eseguita alcuna verifica attiva.

4. Progettazione dello scenario di spear-phishing

Il target strategico rimane Jeff Bezos, mentre il destinatario operativo viene individuato nell'area Finance Operations di Blue Origin. Questa scelta è coerente con il contesto: una persona appartenente al dipartimento Finance potrebbe ricevere comunicazioni da investitori, consulenti, funzioni Legal o soggetti coinvolti nella due diligence. La sottrazione delle credenziali del dipendente costituirebbe l'accesso iniziale e non coinciderebbe ancora, in senso tecnico, con il movimento laterale. Quest'ultimo inizierebbe soltanto qualora l'attaccante utilizzasse l'identità compromessa per raggiungere ulteriori account, applicazioni, gruppi di lavoro o persone interne, avvicinandosi progressivamente alle funzioni Executive e alle risorse collegate a Jeff Bezos.

Elemento	Definizione dello scenario
Target strategico	Jeff Bezos
Organizzazione analizzata	Blue Origin
Contesto OSINT	Primo round significativo con investitori esterni; Coatue indicata come soggetto centrale
Mittente fittizio	Figura Finance di Coatue Management individuata tramite fonti professionali pubbliche
Destinatario	Senior Director - Finance Operations di Blue Origin
Pretesto	Breve riunione riservata per un aggiornamento sulla due diligence
Obiettivo teorico	Acquisizione delle credenziali dell'identità aziendale tramite un falso portale SSO, come possibile accesso iniziale
Sviluppo successivo ipotetico	Movimento laterale verso account e risorse di Finance, Legal, Leadership ed Executive Office, fino a informazioni o relazioni collegate a Jeff Bezos

4.1 Catena di attacco ipotetica e movimento laterale

Nel modello considerato, il furto delle credenziali SSO rappresenta la fase di initial access. Il movimento laterale è una fase successiva e soltanto ipotetica: consiste nello sfruttare la fiducia e le autorizzazioni dell'account compromesso per spostarsi verso altre risorse interne, senza presumere che il primo account consenta un accesso diretto a Jeff Bezos.

- Accesso iniziale: utilizzo dell'identità aziendale sottratta per accedere esclusivamente ai servizi già autorizzati al dipendente compromesso.
- Ricognizione interna: osservazione di rubriche, calendari, gruppi di lavoro, repository documentali e catene di approvazione visibili all'account, allo scopo di comprendere quali relazioni conducano verso Finance, Legal, Leadership ed Executive Office.
- Abuso della fiducia: uso dell'identità interna per rendere più credibili richieste rivolte a colleghi o funzioni adiacenti, ad esempio richieste di condivisione documenti, inviti a riunioni o conferme operative.

- Movimento laterale: tentativo di ottenere l'accesso a un secondo account o a una risorsa con privilegi maggiori, sfruttando relazioni organizzative e processi interni anziché un accesso diretto al target strategico.
- Obiettivo finale: raggiungere informazioni, comunicazioni o interlocutori vicini all'Executive Office e, in ultima istanza, tentare di influenzare o compromettere la catena di fiducia collegata a Jeff Bezos.

Questa catena non implica che il percorso sia garantito: privilegi minimi, segmentazione, MFA resistente al phishing, dispositivi gestiti, controlli sugli accessi e verifiche fuori banda possono interrompere il processo in qualunque fase.

5. Generazione del contenuto tramite LLM

La strategia adottata è stata quella dello **scenario accademico e difensivo**.

Per poter generare la mail atta allo spear phishing tramite LLM, inizialmente è stata esposta la traccia dell'esercizio, specificando di essere uno studente di cybersecurity con l'intenzione di svolgere un'esercitazione a scopi didattici, per ricerca, e per capire vulnerabilità e misure di sicurezza relative al phishing e all'ingegneria sociale.

Successivamente è stato utilizzato questo specifico prompt al quale sono stati aggiunti i nomi e le email rilevate tramite l'OSINT svolto in precedenza:

Adesso genera una mail con lo scopo puramente didattico di simulare uno spear phishing per l'esercizio di cybersecurity che ti ho appena esposto, ovviamente l'intento finale è sempre quello di rilevare problematiche legate alla sicurezza per segnalare eventuali contromisure. All'interno della mail includi le seguenti informazioni:

Mittente:

destinatario:

oggetto: riunione aggiornamento due diligence investimento (puoi modificare l'oggetto se ne trovi uno più calzante)

testo mail: per generare il testo della mail uso un tono formale e cortese per invitare il destinatario a entrare in una riunione online con data e orario usando un link. Implementa i principi di Cialdini dell'urgenza (bisogno di una conferma entro tempi brevi di qualcosa, quindi risposta veloce e riunione breve), impegno e coerenza (le due parti stanno trattando per un investimento, dovrebbero rispondere anche solo per cortesia professionale a una richiesta urgente), e in ultimo un principio tra simpatia e reciprocità.

I nomi, i ruoli professionali e i possibili indirizzi e-mail sono stati ricavati tramite l'attività OSINT svolta in precedenza. L'indirizzo e-mail del mittente potrebbe essere contraffatto utilizzando un dominio omografo, ottenuto sostituendo alcuni caratteri latini con omografi Unicode, come la lettera "a" cirillica. Questa tecnica consente di creare un dominio visivamente molto simile all'originale, pur trattandosi di un dominio tecnicamente differente. L'output finale risulta in questo modo:

Mittente:

David Alba

Head of Finance at Coatue Management

dalba@coatue.com

Destinatario:

William Patterson
Senior Director – Finance Operations at Blue Origin
bpatterson@blueorigin.com

Oggetto:

Conferma entro le 11:30 – briefing riservato sulla due diligence

Gentile Dott. Patterson,

nell'ambito del processo di valutazione dell'investimento, abbiamo riservato una breve sessione di aggiornamento per:

Data: 14/07/2026

Orario: 10:30

Durata prevista: 15 minuti

Modalità: videoconferenza riservata

Per finalizzare l'agenda e abilitare l'accesso ai soli partecipanti autorizzati, le chiediamo di confermare la presenza entro le ore 11:30 di oggi. La verifica richiede meno di un minuto e deve essere effettuata utilizzando l'account aziendale del partecipante.

[Verifica l'accesso e conferma la partecipazione](#) (link button)

Considerata la fase già avviata del processo e la necessità di mantenere la tempistica prevista, una conferma tempestiva ci consentirà di evitare lo spostamento della sessione alla successiva finestra di revisione.

Per agevolare la vostra disponibilità, abbiamo mantenuto riservato questo spazio in agenda e limitato la riunione ai soli aspetti essenziali. Non è richiesta la preparazione preventiva di ulteriore documentazione.

La ringrazio anticipatamente per la collaborazione e resto in attesa della conferma.

Cordiali saluti,

David Alba

(mail stesa in italiano per fini di leggibilità del documento)

Principi di Cialdini applicati: il messaggio utilizza l'**urgenza**, richiedendo una conferma entro poche ore e presentando l'azione come molto rapida;

l'impegno e la coerenza, richiamando un processo di investimento apparentemente già avviato;

la reciprocità, poiché il mittente afferma di avere riservato lo spazio in agenda e limitato la riunione a quindici minuti;

infine, **l'autorità** implicita, sfruttando il ruolo e il prestigio della controparte finanziaria per aumentare la credibilità della richiesta.

La richiesta di autenticazione è plausibile soltanto se presentata come accesso a una riunione riservata mediante identità aziendale/SSO. L'attacco teorico sfrutterebbe invece l'aspettativa di un reindirizzamento verso l'Identity Provider aziendale. Il valore delle credenziali dipenderebbe comunque da MFA, passkey, accesso condizionale, dispositivo gestito e privilegi dell'account.

6. Estensione teorica: deepfake audiovisivo

Il deepfake non è necessario per la fase iniziale di phishing, ma potrebbe agire come amplificatore di fiducia. Un attaccante sofisticato potrebbe usare audio o video sintetici per rappresentare una controparte attesa, giustificare anomalie del portale o indurre la vittima a proseguire con ulteriori azioni o raccogliere ulteriori informazioni.

Il costo e la complessità di un deepfake in diretta sarebbero probabilmente sproporzionati per ottenere una semplice password locale di una piattaforma meeting; diventano più credibili se l'obiettivo è rafforzare una frode BEC, acquisire un'identità aziendale SSO, ottenere informazioni riservate o convincere la vittima ad autorizzare operazioni di elevato valore.

7. Debriefing e analisi critica

7.1 Perché il messaggio potrebbe risultare credibile

- il finanziamento e il ruolo di Coatue sono notizie recenti e coerenti con il momento aziendale;
- il mittente e il destinatario sono associati pubblicamente a funzioni Finance;
- una breve riunione di due diligence è compatibile con le responsabilità del destinatario;
- il tono è formale, cortese e privo di errori evidenti;
- l'azione richiesta appare limitata: verificare l'accesso e confermare una riunione di quindici minuti;
- la pressione temporale è moderata e giustificata con una finestra di revisione, non con una minaccia esplicita.

7.2 Red flag e limiti dello scenario

- dominio del link diverso da coatue.com, blueorigin.com e dai domini noti dell'Identity Provider;
- richiesta di autenticarsi attraverso un collegamento ricevuto per e-mail invece di usare calendario, applicazione o bookmark aziendale;
- riferimenti generici a un processo "già avviato" senza identificativi, contatti interni o conferme verificabili;
- urgenza e scadenza ravvicinata, usate per ridurre il tempo dedicato alla verifica;
- password manager che non propone credenziali sul dominio sconosciuto;
- assenza della riunione dopo il login o errore di accesso, che potrebbe indurre la vittima a segnalare rapidamente l'incidente;
- eventuale MFA o passkey che impedirebbero l'uso della sola password sottratta;
- possibili errori nella deduzione degli indirizzi e-mail o nei rapporti organizzativi.

7.3 Valutazione della superficie informativa

Informazione OSINT	Affidabilità	Utilità per il pretesto	Rischio difensivo
Round di finanziamento e Coatue	Alta come notizia; stato del closing non uniforme	Molto alta	Contesto temporale sfruttabile
Titoli professionali LinkedIn	Media-alta, soggetta ad aggiornamento	Molto alta	Selezione mirata di ruoli Finance
Relazioni gerarchiche	Media-bassa se non ufficiali	Media	Rischio di deduzioni errate

Indirizzi Maltego	Variabile; spesso dedotti	Alta	Possibile targeting nominativo
Host theHarvester	Alta come record raccolto; attualità non verificata	Media	Rivelazione della nomenclatura e dei servizi probabili
Deepfake in diretta	Tecnica possibile ma più complessa	Alta in attacchi ad alto valore	Falso secondo fattore umano

8. Contromisure e raccomandazioni

8.1 Protezione dell'identità e della posta

- adozione di passkey o chiavi FIDO2/WebAuthn per i ruoli Finance, Treasury, Legal, Executive Office e amministratori se non già presenti; CISA e NIST indicano l'autenticazione resistente al phishing come controllo prioritario;
- protezione anti-impersonation per nomi di dirigenti, investitori, studi legali e controparti strategiche;
- DMARC con policy progressivamente restrittiva, insieme a SPF e DKIM, per ridurre lo spoofing diretto;
- analisi di URL e redirect, sandboxing dei contenuti e blocco dei domini appena registrati o simili a marchi noti;
- conditional access basato su dispositivo gestito, rischio dell'utente, posizione e comportamento;
- monitoraggio di accessi anomali, nuovi device, richieste OAuth e tentativi di MFA fatigue.

8.2 Processi Finance e gestione delle riunioni

- verifica fuori banda delle richieste urgenti utilizzando recapiti presenti nella rubrica aziendale e non quelli inclusi nel messaggio;
- accesso alle riunioni tramite calendario e applicazioni ufficiali, evitando l'inserimento di credenziali dopo aver seguito link inattesi;
- doppia approvazione per pagamenti, modifiche di coordinate bancarie, accesso a data room e condivisione di documenti sensibili;
- workflow formale per nuovi investitori e advisor, con elenco di contatti autorizzati condiviso tra Finance, Legal e Security;
- parola di verifica o challenge fuori banda per richieste eccezionali, incluse quelle ricevute durante chiamate audio/video;
- playbook di risposta rapida: revoca sessioni, reset credenziali, blocco token, analisi log e segnalazione interna immediata.

8.3 Prevenzione del movimento laterale

Poiché l'obiettivo strategico ipotizzato richiede di passare da un account Finance compromesso a funzioni più vicine alla leadership, la difesa deve limitare il valore dell'accesso iniziale e impedire che la fiducia interna venga utilizzata come scorciatoia.

- applicare il principio del privilegio minimo e revisioni periodiche di gruppi, ruoli, deleghe di casella, accessi a calendari, data room e repository condivisi;
- segmentare le applicazioni e i dati delle funzioni Finance, Legal, Leadership ed Executive Office, evitando che un singolo account possa attraversare più domini informativi senza ulteriori controlli;

- richiedere nuova autenticazione e controlli contestuali per operazioni sensibili, accesso a documenti riservati, aggiunta a gruppi privilegiati o apertura di sessioni da dispositivi non gestiti;
- monitorare l'invio anomalo di messaggi interni, la creazione di regole di inoltramento, l'uso insolito di caselle condivise, le richieste di accesso a documenti e le modifiche alle deleghe;
- proteggere gli account executive e degli assistenti con identità separate, passkey o chiavi FIDO2, accesso da dispositivi gestiti e procedure di verifica fuori banda;
- non considerare automaticamente affidabile una richiesta solo perché proviene da un dominio o da un account interno; per azioni sensibili deve essere verificato anche il contesto operativo;
- predisporre playbook specifici per la compromissione di un account Finance: revoca delle sessioni, invalidazione dei token, revisione delle regole di posta, controllo delle condivisioni e ricerca di messaggi interni usati per ulteriori tentativi di phishing.

8.4 Raccomandazioni specifiche per l'esposizione LinkedIn

Il post LinkedIn analizzato non costituisce di per sé una violazione: è un contenuto professionale legittimo. Il rischio nasce dalla correlazione tra post, commenti, titoli, date e profili individuali. Nel caso esaminato, tali elementi hanno permesso di ricostruire una porzione significativa dell'area Finance e di selezionare ruoli compatibili con un pretesto di investimento. Le raccomandazioni sono quindi orientate alla minimizzazione, non alla completa rinuncia alla presenza professionale online.

- introdurre una revisione Security/Corporate Communications per i post che mostrano team completi, iniziative strategiche, round di finanziamento, data room, nuove partnership o operazioni straordinarie;
- limitare tag e menzioni quando non necessari, perché consentono di passare dal post ai profili e di ricostruire rapidamente l'organigramma;
- usare descrizioni professionali sufficienti per il recruiting e il networking, ma evitare dettagli su processi interni, strumenti, responsabilità di approvazione e relazioni di riporto;
- formare i dipendenti a riconoscere che commenti apparentemente innocui, congratulazioni e interazioni pubbliche possono confermare l'appartenenza a un team;
- eseguire periodicamente un'analisi OSINT esterna della propria organizzazione per verificare quali organigrammi, indirizzi probabili e relazioni siano ricostruibili;
- avviare simulazioni di spear-phishing subito dopo annunci pubblici importanti, usando scenari coerenti con le informazioni effettivamente esposte;
- monitorare domini typosquatting e profili social falsi che imitano dirigenti, investitori o figure Finance;
- predisporre un canale semplice per segnalare contenuti social ritenuti eccessivamente informativi senza attribuire colpe al singolo dipendente.

8.5 Gestione dell'esposizione tecnica

- inventario continuo dei sottodomini e rimozione dei record obsoleti, soprattutto per ambienti dev, stage e test;
- adozione di naming meno descrittivo per servizi sensibili quando possibile, evitando di rivelare direttamente funzione e tecnologia;
- monitoraggio Certificate Transparency e fonti passive per conoscere la superficie che un attaccante può enumerare;
- revisione degli host pubblici, accesso tramite Zero Trust/VPN e segmentazione delle interfacce amministrative;

- verifica periodica che portali, SFTP, sistemi di autenticazione e servizi legacy non espongano banner o pagine informative non necessarie.

9. Conclusioni

L'esercitazione ha dimostrato che un attacco di spear-phishing può essere costruito combinando fonti comuni e apparentemente innocue. La notizia del round finanziario fornisce il contesto; LinkedIn permette di individuare funzioni e ruoli; Maltego consente di correlare i dati e stimare pattern e-mail; theHarvester amplia la conoscenza della superficie esterna e della nomenclatura tecnica.

Il pretesto scelto è credibile perché collega una controparte realmente citata dalla stampa a un ruolo Finance compatibile con la due diligence. L'obiettivo teorico non è la password locale di una singola applicazione, ma l'identità aziendale usata per l'accesso SSO. La compromissione costituirebbe soltanto l'accesso iniziale: un eventuale avversario dovrebbe poi tentare un movimento laterale attraverso risorse, gruppi e relazioni interne, con l'obiettivo di avvicinarsi alle funzioni Executive e alle informazioni collegate a Jeff Bezos. La riuscita non è garantita: dominio anomalo, password manager, passkey, MFA resistente al phishing, accesso condizionale, privilegi minimi, segmentazione e verifica fuori banda possono interrompere la catena.

La principale conclusione difensiva riguarda la gestione congiunta della superficie tecnica e umana. La sicurezza non dipende soltanto dai filtri e-mail, ma anche da processi Finance robusti, autenticazione resistente al phishing, formazione contestuale e controllo dell'esposizione OSINT. In particolare, i contenuti LinkedIn dovrebbero essere valutati non solo singolarmente, ma per ciò che diventano quando vengono aggregati con profili, commenti, notizie e dati di dominio.